

Sécurité, coûts et appropriation

Comment la plateforme FASTR protège les données d'un pays — et ce qu'il faut pour la faire tourner

»» FASTR Useful Data

Sécurité des données

The background is a solid teal color. On the right side, there are several overlapping geometric shapes: a large dark teal quarter-circle in the top right, a smaller dark teal quarter-circle in the bottom right, and a series of concentric light teal circles centered near the bottom right corner.

Ce que « sécurisé » veut dire pour une telle plateforme

La sécurité d'une plateforme de données recouvre cinq dimensions distinctes. Les diapositives suivantes traitent chacune d'elles : le risque, et les mesures en place.

Cinq dimensions de la sécurité des données et de la plateforme

Confidentialité

Seules les personnes autorisées voient les données

Qui peut y accéder ?

Intégrité

Les chiffres ne peuvent être altérés à l'insu de tous

Peut-on se fier aux chiffres ?

Disponibilité

Accessibles quand il le faut

Que se passe-t-il si un serveur tombe ?

Souveraineté

Sous contrôle national

Qui détient les données, in fine ?

Traçabilité

Chaque action est journalisée

Qui a fait quoi, et quand ?

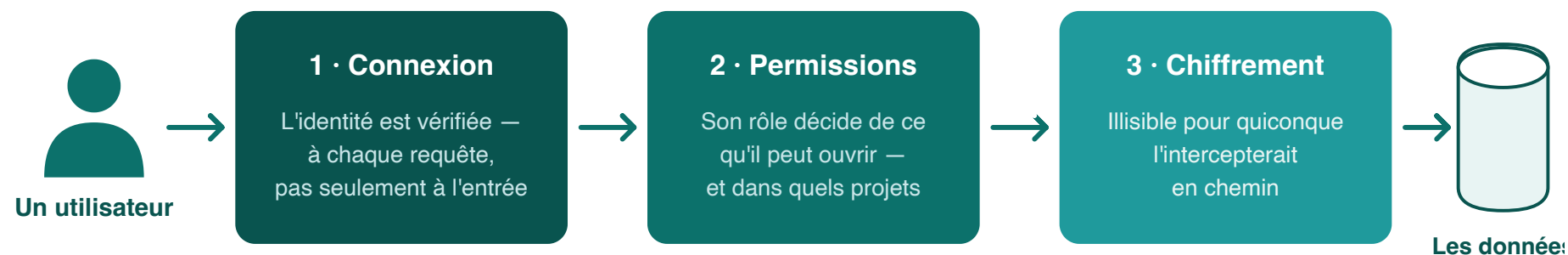
Le point de départ : ce que contient la plateforme

- Des **totaux mensuels de services par établissement** — par exemple, 45 premières consultations prénatales dans une clinique en mars
- Les **mêmes chiffres que les rapports DHIS2** que le ministère produit déjà
- **Aucun dossier patient** — pas de noms, pas d'adresses, rien d'individuel
- **Périmètre actuel, par conception** : l'hébergement de données individuelles reste possible à l'avenir, sous réserve des garanties supplémentaires détaillées dans l'annexe technique

Confidentialité — qui peut accéder aux données

Le risque : un accès non autorisé, de l'extérieur comme de l'intérieur. Les mesures : des comptes nommés et des rôles, une identité revérifiée à chaque requête, le chiffrement en transit.

Trois contrôles séparent un utilisateur des données



À part : la protection contre la perte

La base est sauvegardée toutes les 30 minutes, l'installation complète chaque jour — si un serveur tombe, tout peut être reconstruit

Intégrité — peut-on se fier aux chiffres

Le risque : des chiffres modifiés sans trace, ou des analyses impossibles à reproduire. Les mesures : une source de vérité, des importations enregistrées, des résultats versionnés.

- **DHIS2 reste la source de vérité** — la plateforme importe depuis DHIS2, et les mois réimportés sont rafraîchis pour y correspondre
- **Chaque importation est enregistrée** : un registre indicateur par indicateur montre les mois chargés, quand, et les échecs éventuels
- **Les résultats arrivent en paquets versionnés et datés** — le même paquet donne les mêmes chiffres à tous ; de nouveaux chiffres exigent un nouveau paquet
- Les méthodes d'analyse et leurs paramètres sont **documentés et consignés avec chaque paquet**

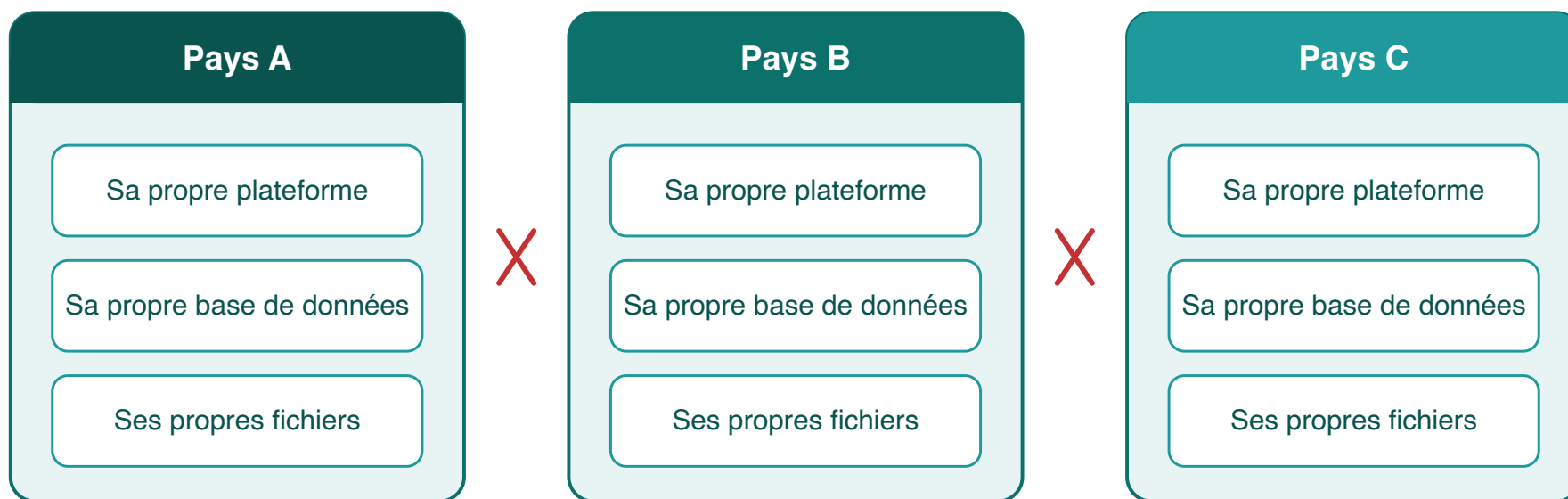
Disponibilité — que se passe-t-il si un serveur tombe

Le risque : une panne matérielle, une suppression accidentelle ou une importation corrompue. Les mesures : des sauvegardes automatiques en couches et un chemin de récupération éprouvé.

- La **base de données est sauvegardée toutes les 30 minutes**, avec une fenêtre glissante de trois jours
- Des **instantanés complets de l'installation** sont conservés selon un cycle quotidien, hebdomadaire et mensuel
- Une **instance pays entière peut être reconstruite** à partir de ces instantanés
- Créer ou restaurer une sauvegarde exige une **permission explicite** en plus d'une connexion valide

Souveraineté — les données restent celles du pays

Le risque : des données versées dans un espace partagé, ou visibles d'un autre pays. Les mesures : des installations entièrement isolées, et l'export intégral à tout moment.



Aucune connexion entre les pays — par conception

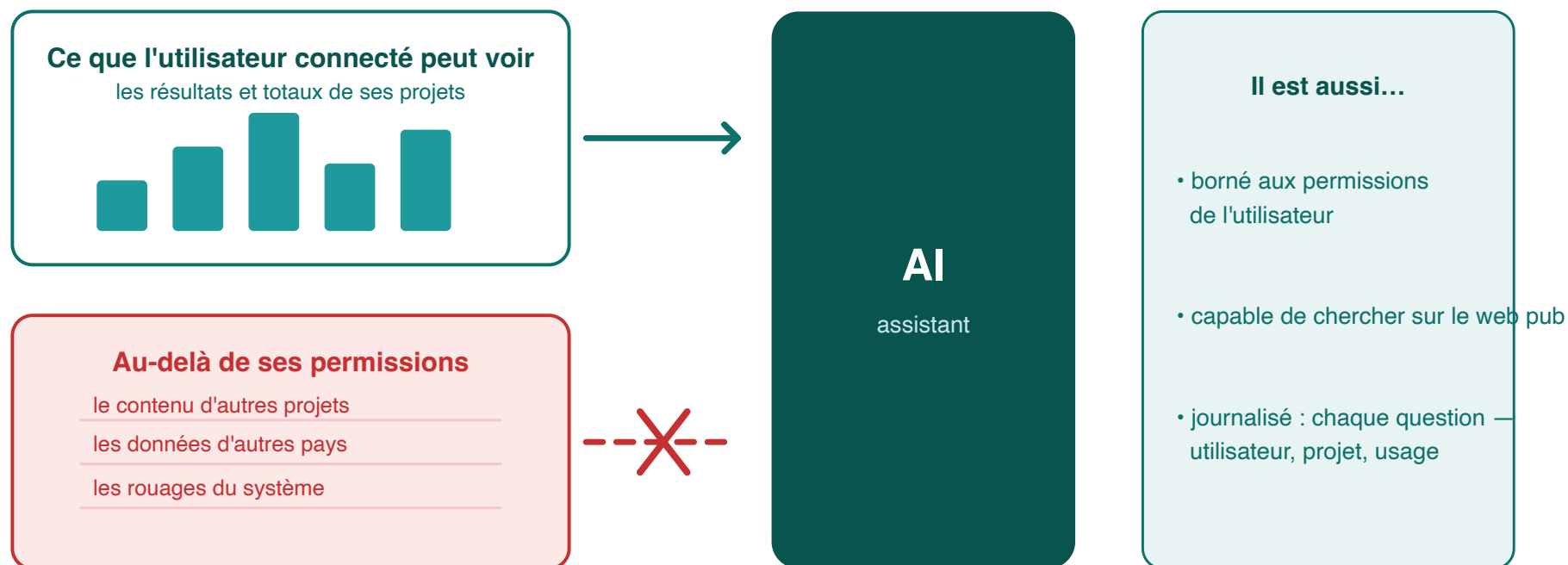
Traçabilité — chaque action est attribuable

Le risque : des modifications ou des accès que personne ne peut retracer. Les mesures : chaque requête liée à un compte nommé, et des journaux opérationnels sur toute la plateforme.

- Chaque requête s'exécute sous un **compte nommé et vérifié** — aucune action anonyme
- **Les importations sont enregistrées** par indicateur et par mois ; **les paquets de résultats sont datés et versionnés**
- **Les sauvegardes et restaurations sont contrôlées par permission** et attribuables
- **Chaque question posée à l'IA est journalisée** : qui, sur quel projet, avec quel usage

Application à l'assistant IA

L'IA ne voit que ce que l'utilisateur connecté peut voir, et chaque question est journalisée. Elle reçoit des chiffres agrégés, calculés par la plateforme pour cette question, jamais la base de données. Selon les conditions commerciales d'Anthropic, ces chiffres **ne servent pas à entraîner les modèles** et sont **supprimés sous 30 jours**. L'analyse par établissement, une fois introduite, gardera la même limite de permissions.



Coûts et appropriation

The background of the slide is a solid teal color. On the right side, there are abstract geometric elements: a large dark teal quarter-circle in the top right, a smaller dark teal quarter-circle in the bottom left, and two sets of concentric circles. One set of circles is centered near the bottom left, and the other is centered near the bottom right. The circles are light teal and fade out towards the right edge.

Coûts de fonctionnement

Les coûts de fonctionnement tiennent en trois lignes : un **hébergement fixe** pour le serveur du pays, l'**usage de l'IA au compteur** (l'API Anthropic), et la **maintenance partagée** de la plateforme, qui couvre aussi les services externes comme le **service de connexion Clerk**. Le logiciel lui-même est open source — ni licence ni frais par utilisateur.

Hébergement	Assistant IA	Personnes
Montant annuel fixe Un montant mensuel fixe pour le serveur du pays ≈ 500–800 USD / an	Facturé à l'usage Au compteur — vous ne payez que ce qui est utilisé ≈ 350 USD / mois	Partagée entre pays Mises à jour, supervision, sauvegardes, appui aux utilisateurs ≈ 7–10 k USD / an, partagé

Estimations de planification, prix 2026 — ni licences ni frais par utilisateur

Les chiffres — estimations de planification

Ce sont des estimations de planification, aux prix 2026 et à l'usage actuel — **non un devis**.

- **Hébergement** de l'instance : environ **500 à 800 USD par an** — les grands pays vers le haut de la fourchette
- **Usage de l'IA** (l'API Anthropic) : environ **350 USD par mois** (~4 000 USD par an) pour un pays typique ; plusieurs fois plus pour les plus grands, en croissance avec l'usage
- **Maintenance partagée** (ingénierie, supervision, sauvegardes, service de connexion Clerk) : environ **7 000 à 10 000 USD par pays et par an**, en baisse à mesure que des pays rejoignent — une économie d'échelle qui disparaît en auto-hébergement
- **Appui optionnel** (actualisation des données, contrôles qualité, analyses) : environ **5 000 à 15 000 USD par an** selon le niveau
- **Total : environ 12 000 USD par an** — jusqu'à 20 000–30 000 USD avec l'appui ; aucun autre abonnement

Hébergement — et ce que migrer demande vraiment

- Hébergée **de façon centralisée aujourd'hui**, pendant le développement actif — chaque pays reçoit correctifs et nouveautés le jour même
- Construite **portable** : le même logiciel tourne tel quel sur les serveurs d'un ministère — aucune reconstruction
- **La migration est un projet structuré** : évaluation de préparation, achat des serveurs, formation de l'équipe, période de fonctionnement en parallèle, puis bascule — un **calendrier en mois, planifié conjointement**
- **L'auto-hébergement transfère au ministère les fonctions partagées** : maintenance, supervision et application de chaque mise à jour — déployée aujourd'hui centralement pour tous les pays à la fois — relèvent alors de l'équipe du ministère, et un appui instance par instance entraîne un coût supplémentaire
- **Toutes les données d'un pays peuvent être exportées intégralement à tout moment**, quel que soit l'hébergement

Le chemin vers l'appropriation par le pays

Pour les pays qui souhaitent s'héberger eux-mêmes, un effort du ministère de la Santé sera nécessaire. Une équipe devra faire tourner serveurs, sauvegardes et mises à niveau ; et des marchés devront être en place pour l'hébergement et pour les services d'IA, achetés auprès d'un fournisseur commercial (par ex. Anthropic, OpenAI).



L'essentiel

- **Des totaux agrégés aujourd'hui** — aucun dossier patient ; l'hébergement futur de données individuelles est conditionné à des garanties supplémentaires
- **La sécurité sur cinq dimensions** — installations isolées par pays, accès par rôles, importations enregistrées et résultats versionnés, sauvegardes en couches, journaux d'audit complets
- **Environ 12 000 USD par an** de fonctionnement — hébergement, IA au compteur, maintenance partagée ; ni licence ni frais par utilisateur
- **Hébergement par le pays d'ici 2030** — l'objectif affiché ; une migration structurée qui transfère mises à jour et maintenance au ministère, avec un coût supplémentaire probable par pays

Annexe technique — pour les équipes informatiques et DHIS2

Architecture et isolation

- Chaque instance pays est un **déploiement Docker séparé** : son conteneur applicatif, sa base **PostgreSQL**, son cache **Valkey**, son volume de stockage, sur un réseau privé
- Au sein d'une instance, chaque projet a sa **propre base** (`project_{uuid}`) pour le contenu d'édition
- Les résultats calculés résident dans des **paquets de résultats versionnés** (fichiers parquet, interrogés via DuckDB) — les projets lisent le paquet qui leur est rattaché, jamais celui des autres

Authentification et contrôle d'accès

- L'identité est gérée par **Clerk** (fournisseur d'identité géré) ; les jetons de session sont **vérifiés par middleware à chaque requête** — le contournement d'authentification n'existe qu'en développement local, désactivé en production
- **RBAC à deux niveaux** : permissions d'instance et rôles par projet, résolus en base à chaque requête
- Accès aux serveurs : **SSH par clé cryptographique uniquement**, restreint à deux ingénieurs nommés — pas de connexion par mot de passe

Protection des données et exploitation

- **TLS terminé sur nginx**, certificats provisionnés et renouvelés via certbot ; les secrets sont injectés en variables d'environnement à l'exécution — jamais dans les images, jamais côté navigateur
- **Les modules R s'exécutent dans des conteneurs éphémères** (supprimés à la fin) qui ne montent que le répertoire de travail de leur exécution
- Sauvegardes : **pg_dump toutes les 30 minutes** (fenêtre glissante de 3 jours) plus **instantanés de volume quotidiens / hebdomadaires / mensuels** ; la restauration est contrôlée par permission (`can_restore_backups`) et par une clé côté serveur en plus d'une session valide

L'intégration IA, précisément

- Claude (Anthropic) est atteint via un **proxy côté serveur** ; la clé d'API ne quitte jamais le serveur
- Les appels d'outils s'exécutent **dans la session authentifiée de l'utilisateur** — l'IA n'a aucune permission propre
- Les outils de données renvoient actuellement des **sorties métriques agrégées** (aucune dimension identifiant d'établissement en v1.67 ; longues dimensions résumées en nombres) ; l'accès prévu au niveau des établissements suivra le **même modèle de permissions de session**
- **Conditions commerciales d'Anthropic** : le contenu client ne sert pas à entraîner les modèles, est confidentiel et est supprimé sous 30 jours par défaut ; accord de rétention zéro et DPA disponibles ; données stockées aux États-Unis
- La **recherche web côté serveur (hébergée par Anthropic)** est **activée** dans le chat projet pour les questions générales
- Chaque requête est journalisée (utilisateur, projet, modèle, jetons) ; **des limites quotidiennes par utilisateur et hebdomadaires par instance** s'appliquent

Données et interopérabilité

- Données source : **numérateurs DHIS2 agrégés** (totaux établissement-mois) — importés côté serveur, avec remplacement par paire (indicateur, mois) et un registre d'importation par indicateur
- **Export intégral à tout moment** : les données et résultats d'un pays sont exportables quel que soit l'hébergement
- Le code est **open source** : github.com/FASTR-Analytics/platform

Si des données patients étaient hébergées : les exigences

Le périmètre agrégé est une décision de conception, non une limite technique. L'hébergement de données individuelles serait conditionné aux garanties suivantes :

- **La base légale d'abord** : conformité au droit national de protection des données et des données de santé, accords de partage — et possiblement **l'hébergement dans le pays** comme précondition
- **Chiffrement au repos** en plus du chiffrement en transit ; **pseudonymisation** partout où l'analyse le permet
- **Accès au strict nécessaire** : rôles plus fins, restrictions par champ, et journaux d'audit sur chaque accès à un enregistrement
- Des procédures formelles de **réponse aux incidents et de notification des violations**, des tests de sécurité indépendants et des pratiques de niveau certification
- **Gouvernance ministérielle** : une autorité désignée d'accès aux données décidant qui peut voir quoi, et pourquoi